

Lab 1 - Reconnaissance

Reconnaissance is the first process in Ethical Hacking to find and get to know the target system(s). Reconnaissance involves a set of techniques and tools used to discover and collect as much information about a target system as possible. Reconnaissance may take place in **Active Reconnaissance** or **Passive Reconnaissance**.

2 IP addresses: You have permission to conduct Ethical Hacking.

- your own IP address as Defender
- an IP address assigned to your group as Attacker

Domain name: Please use **Passive Reconnaissance since you haven't got permission**.

- **Passive Reconnaissance:** you will not be directly connected to the target system.
- **singaporetech.edu.sg**
- **other domain names**

Through Reconnaissance, you as Attacker can collect the following information:

- Domain name
- IP Addresses
- Namespaces
- Server technologies
- OS platforms
- Security Information
- Etc.

From the site report, you may be able to get info like IP address, domain registrar, nameserver, hosting history, site technology etc. Site technology e.g. provides information of what technologies the site is running and from here the attacker can seek out vulnerabilities in these named technologies from sites like <https://cve.mitre.org/>

Exercise 1: Domain Name Information - Whois

You can use a whois website to get detailed information about a domain name - information including its owner, its registrar, date of registration, expiry, name server, owner's contact information, etc. There are many whois sites you can use:

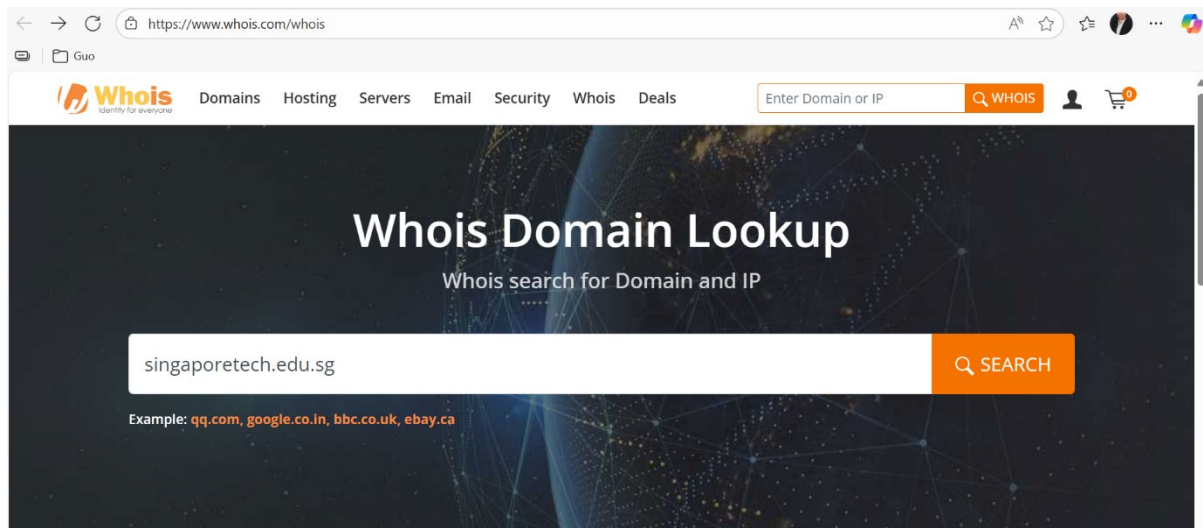
- <http://www.whois.com/whois>
- <https://who.is/>
- <http://whois.domaintools.com/>

Output contains:

- Domain name owner (registrant)
- E-mail addresses
- Name servers for domain name in question
- Name and contact info of admin, technical staff etc.

As people are usually the weakest security link, you can use social engineering to gather further information with the information from whois.

- Browse to <https://www.whois.com/whois> . You will see a page similar to this:



- Enter a few domain names as in Exercise 1. What information can you get?
- Repeat with other whois sites and compare the information returned to you.

Exercise 2: DNS Data View, Nslookup and Dig

Reconnaissance can also be done with tools and commands, e.g., nslookup and dig. If you have Kali Linux, you can also use the **nslookup** or **dig** commands.

- **nslookup**
 - name server lookup; used to query internet name servers interactively
 - It can translate a domain name to an IP address or vice versa
 - nslookup – name server lookup; used to query internet name servers interactively

```
(kali㉿kali)-[~]
└─$ nslookup singaporetech.edu.sg
```

What information can you get after the above command?

- **dig**

```
(kali㉿kali)-[~]
└─$ dig singaporetech.edu.sg
```

What information can you get after the above command?

If you have a Windows-based system, you can install DNS Data View from the link: https://www.nirsoft.net/utils/dns_records_viewer.html or you can use the nslookup command.

You can also invoke nslookup from here: <https://centralops.net/co/nslookup.aspx>

Exercise 3: Netcraft

Provides internet security and data mining services

<https://searchdns.netcraft.com/>, <https://www.netcraft.com/>

Can be used to footprint a website

Output contains:

- Domain name owner (registrant)

- Nameserver for domain name in question
- Domain registrar
- DNS admin email address
- SLS/TLS Protocol Version
- Certificate
- Web site technologies

<https://searchdns.netcraft.com/>, input www.singaporetech.edu.sg, or <https://www.singaporetech.edu.sg>.

- What information can you get?
- What are the differences between www.singaporetech.edu.sg and <https://www.singaporetech.edu.sg>?

Exercise 4: Builtwith

Web-based reconnaissance tool

Located at: <https://builtwith.com/>

Find out what technologies a website is built with.

Outputs include:

- Analytics and Tracking
- Frameworks
- Content Delivery Network
- JavaScript Libraries and Functions
- Web Hosting Providers
- Email Hosting Providers
- SSL Certificates
- Web Servers

<https://builtwith.com/>, input singaporetech.edu.sg, what information will you get?

Exercise 5: Google Hacking

Business assets can be considered to be and include items such as valuable and sensitive data that need to be kept secure and confidential. For example, financial data, client information or employee contract details.

- Try out the following searches and see what you get
- Sample Searches:
 - intitle:"index of" finance.xls
 - "welcome to intranet"
 - intitle:"gateway configuration menu"
 - ext: xlsx inurl:password

Exercise 6: Information Disclosure

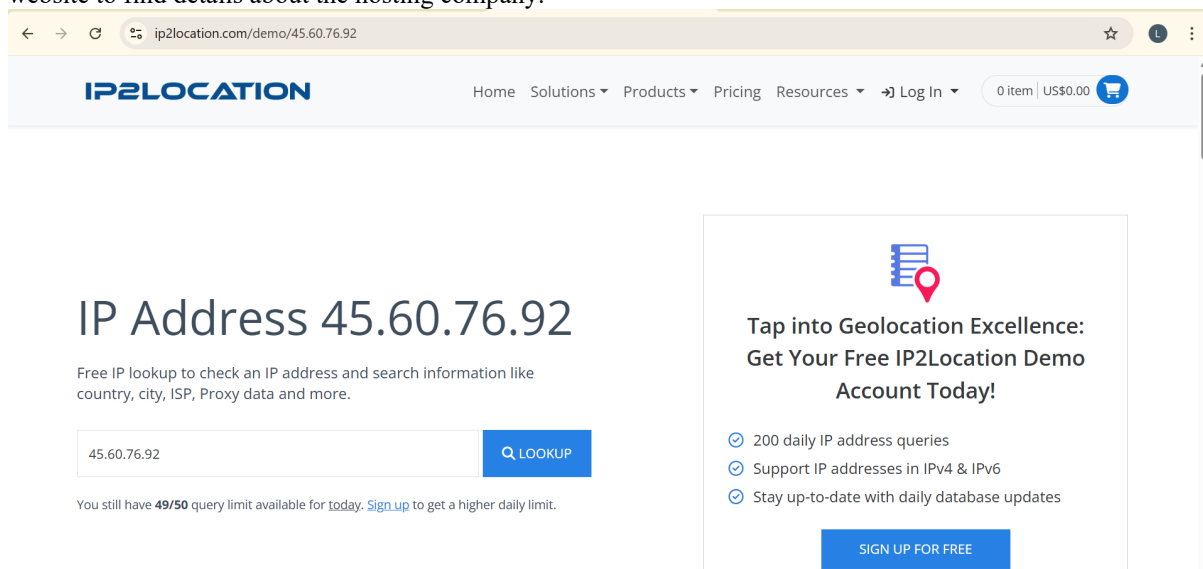
- Database definitions and dumps:
 - #mysql dump filetype:sql (for SQL definition files)
 - filetype:ora oracle (for Oracle configuration files)
- Exported Registry Settings:
 - filetype:reg reg +intext:"internet account manager" (allows you to download the registry to possibly get info like usernames, mail server settings, email addresses etc.)
- Login Credentials:
 - intext:@pwcache "parent directory" (email passwords publicly available on the Internet)

Exercise 7: Vulnerability Assessment

- `intitle:"Welcome to IIS 4.0"` will find several installations of Internet Information Service 4.0 (and above) server
- `intitle:"Cisco Systems, Inc. VPN 3000 Concentrator"` will get you access to the web interface and chances are some of these may have the default username and password (admin)
- `inurl:printer/main.html intext:settings` will give you access to publicly accessible network printers

Exercise 8: ip2location.com

Once you have found a website address, you can get further details by using the www.ip2location.com website to find details about the hosting company.



The screenshot shows the IP2Location website interface. The browser address bar displays `ip2location.com/demo/45.60.76.92`. The website header includes the IP2LOCATION logo and navigation links: Home, Solutions, Products, Pricing, Resources, Log In, and a shopping cart icon showing 0 items for US\$0.00. The main content area features a large heading "IP Address 45.60.76.92" and a subheading "Free IP lookup to check an IP address and search information like country, city, ISP, Proxy data and more." Below this is a search input field containing "45.60.76.92" and a "LOOKUP" button. A message below the input field states: "You still have 49/50 query limit available for today. Sign up to get a higher daily limit." To the right, a promotional box titled "Tap into Geolocation Excellence: Get Your Free IP2Location Demo Account Today!" lists three benefits: 200 daily IP address queries, support for IPv4 & IPv6, and daily database updates. A "SIGN UP FOR FREE" button is at the bottom of this box.

Experiment with google dorks and attempt to find different internet-connected devices. Use what you have learned to determine the locations of these devices.

Exercise 9: <https://www.iplocation.net/ip-lookup>

- <https://www.iplocation.net/ip-lookup>
Input IP address, what information can you get?

Exercise 10: SSL Report

<https://www.ssllabs.com/ssltest/index.html>

Input `singaporetech.edu.sh`, what information can you get?

Exercise 11: curl

`$ curl -I -L IP address (in Kali Linux)`

What information can you get?

Exercise 12. Web Application Firewall

To find a web application firewall (WAF): `wafw00f` IP address (in Kali Linux)

What information can you find?